



UNIVERSIDAD TECNOLÓGICA DE TEHUACÁN

Nombre Del Alumno:

Alejandro Contreras Martinez

Emmanuel Castro Salvador

Carlos Eduardo Hernandez

Camacho

Danna Paola Tobón Mosqueda

Manelic Alitzel Reyes Torres

Docente:

José Miguel Carrera Pacheco

**Protección de rutas y recursos por
rol**

**ING EN DESARROLLO
DE SOFTWARE
MULTIPLATAFORMA**

1. Objetivo

Validar que el sistema controle correctamente el acceso según el tipo de usuario y su estado de autenticación, asegurando que:

- un usuario con rol user solo pueda acceder a funciones permitidas,
- un usuario con rol admin pueda acceder a funciones administrativas,
- el sistema responda con códigos adecuados como 401 Unauthorized y 403 Forbidden cuando corresponda.

2. Alcance

Se evaluaron los accesos en:

- API
 - /auth/register
 - /auth/login
 - /reports
 - /reports/mine
 - /reports/:id
 - /admin/reports
 - /admin/reports/:id/status

3. Roles evaluados

3.1 Usuario user

Usuario autenticado con permisos básicos del sistema.

3.2 Usuario admin

Usuario autenticado con privilegios administrativos.

3.3 Usuario sin Token

Usuario sin autenticar sin privilegios

4. Casos de prueba ejecutados

Los casos de pruebas realizados se describen

1. Login

Se ejecutaron pruebas considerando:

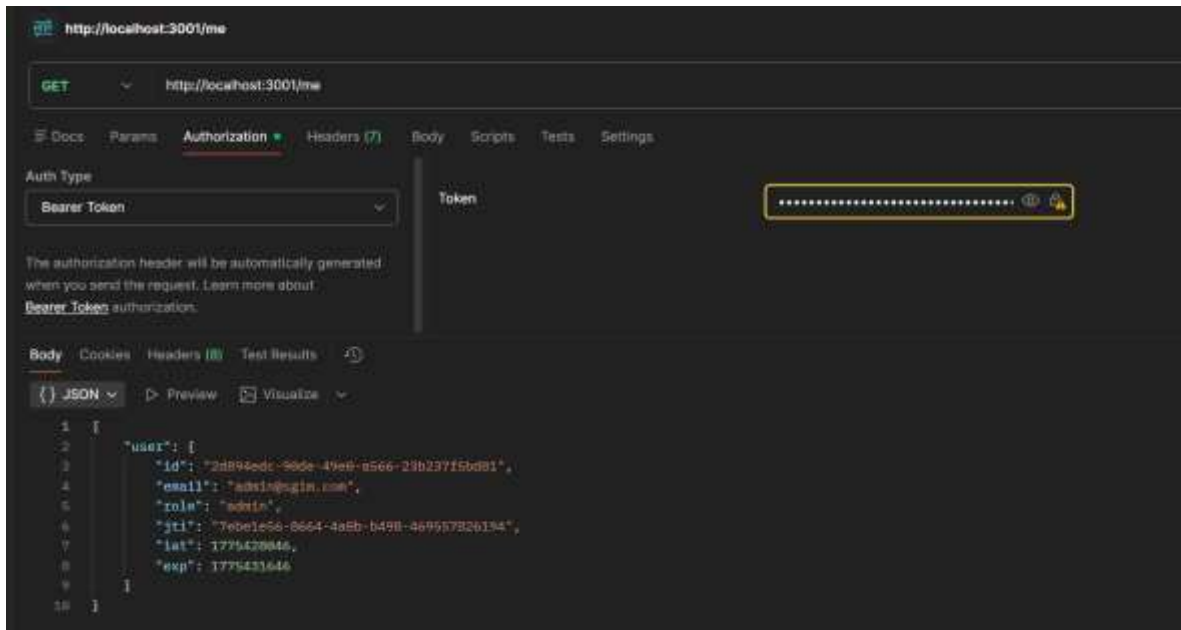
- [illegible]

-
- The screenshot shows a REST client interface. The top bar indicates a POST request to `http://localhost:3000/login`. The request body is set to raw JSON: `{ "email": "admin@localhost.com", "password": "123456" }`. The response is a 401 Unauthorized status with a JSON body: `{ "error": "Unauthorized", "message": "Invalid login details" }`.

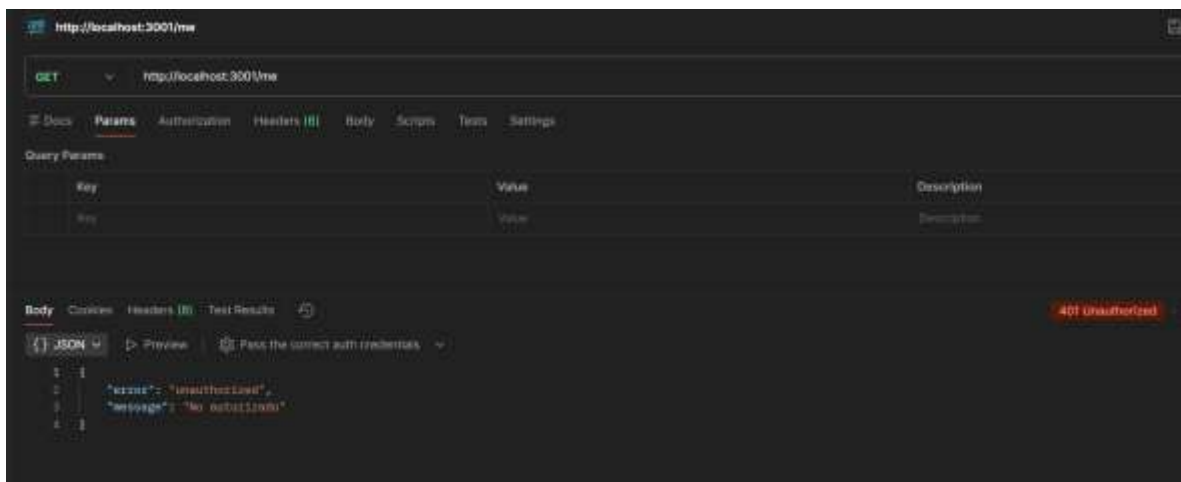
2. Profil

Se probaron los siguientes escenarios:

- acceso con token válido → el sistema devuelve los datos del usuario (200 OK).



- acceso sin token → el sistema rechaza la solicitud (401 Unauthorized).



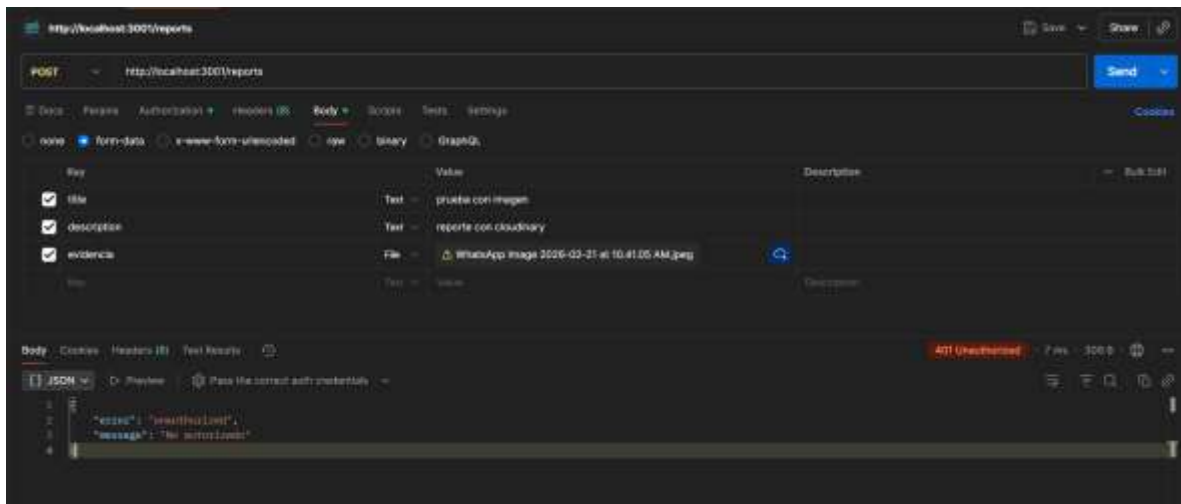
Con estas pruebas se busca el poder verificar que solo usuarios autenticados pueden consultar su información.

3. Reportes

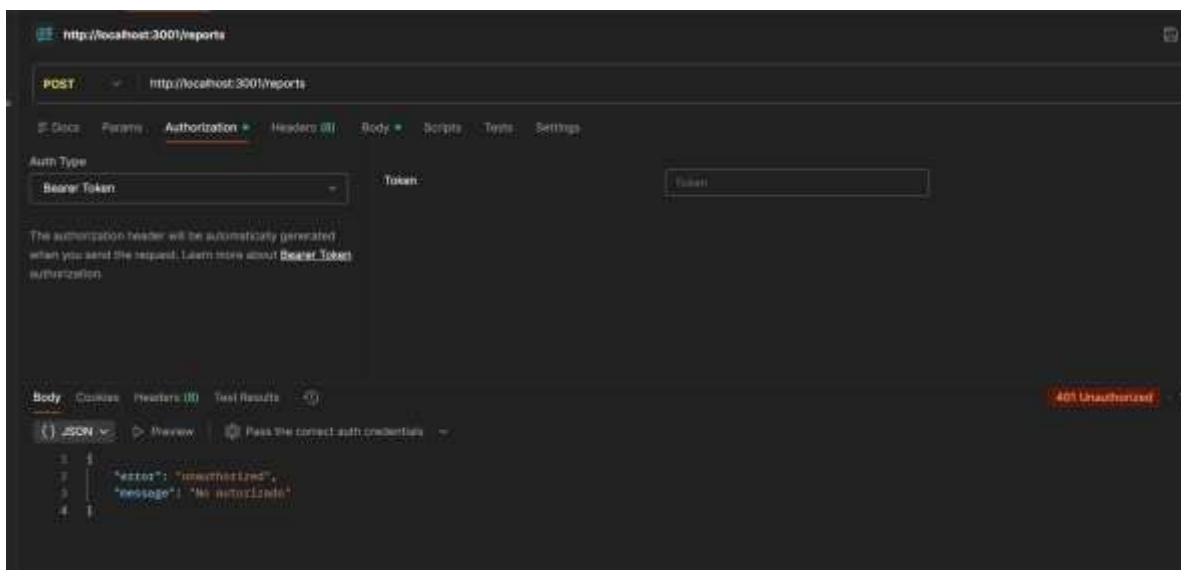
Se valida que los usuarios autenticados puedan generar reportes dentro del sistema.

Escenarios probados:

- usuario autenticado envía datos correctamente → el sistema crea el reporte (200 OK / 201 Created).



- usuario sin token → el sistema rechaza la operación (401 Unauthorized).



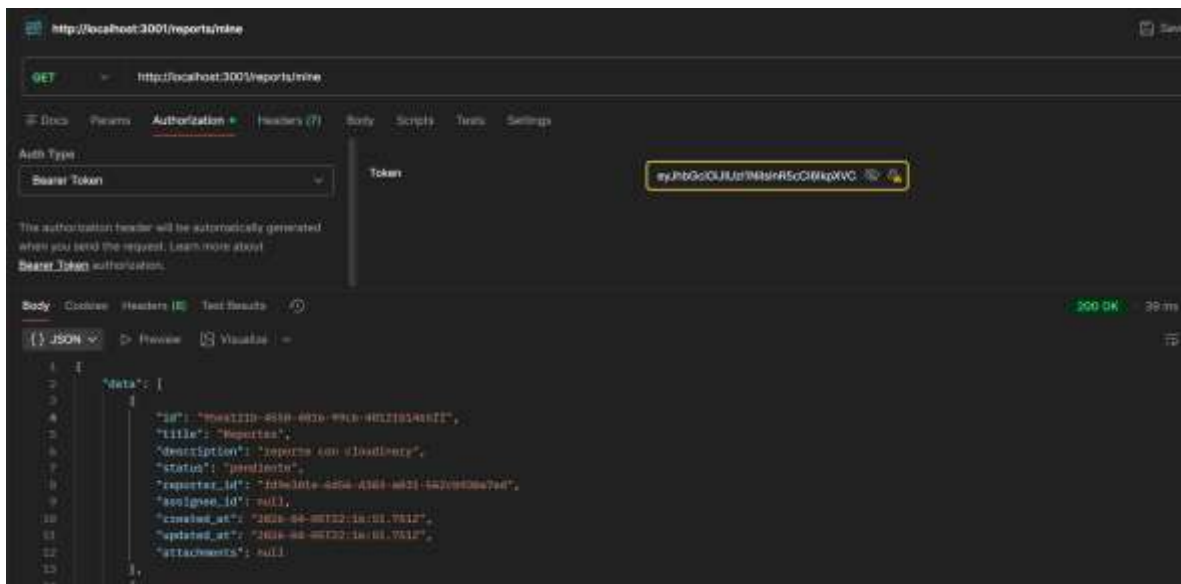
Con estas pruebas buscamos confirmar que la creación de reportes está restringida a usuarios autenticados y que el sistema procesa correctamente la información enviada.

4. Mis reportes

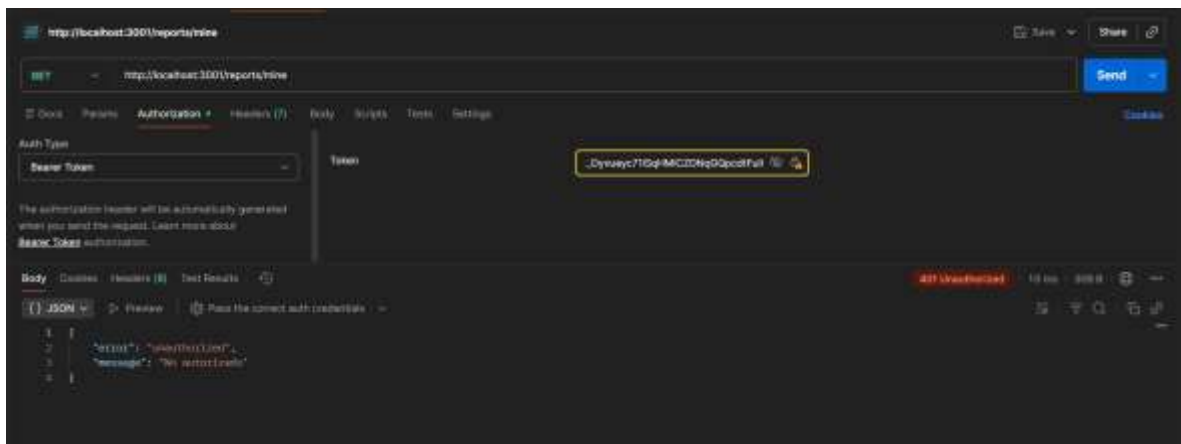
Se valida que un usuario autenticado pueda consultar únicamente sus propios reportes.

Escenarios:

- usuario autenticado → el sistema permite el acceso (200 OK).



- usuario sin autenticación → el sistema rechaza el acceso (401 Unauthorized).



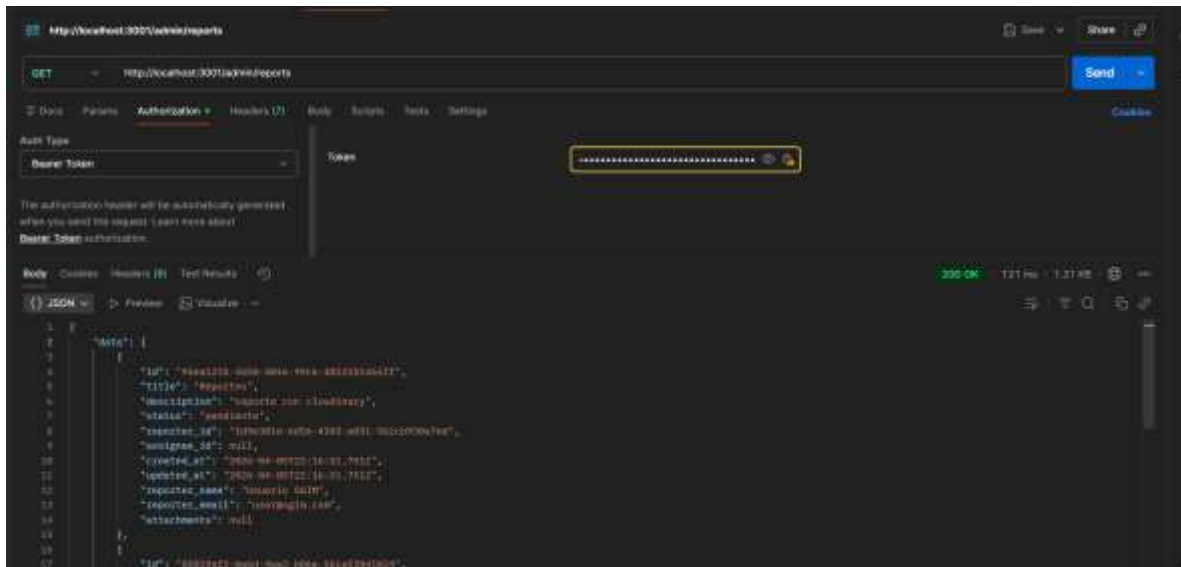
Con esta prueba se busca el asegurar que la consulta de reportes está protegida y vinculada a la sesión del usuario.

5. Reportes administrativos

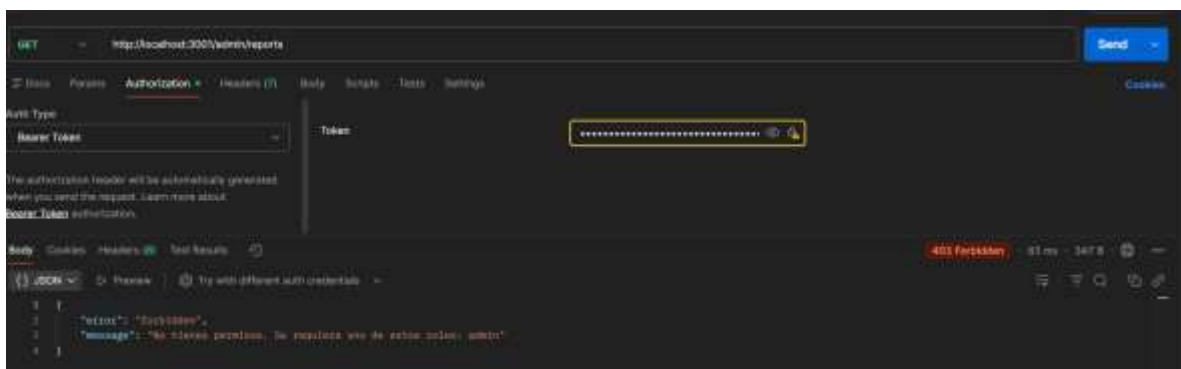
Se valida que solo usuarios con rol admin puedan acceder a la información administrativa.

Escenarios:

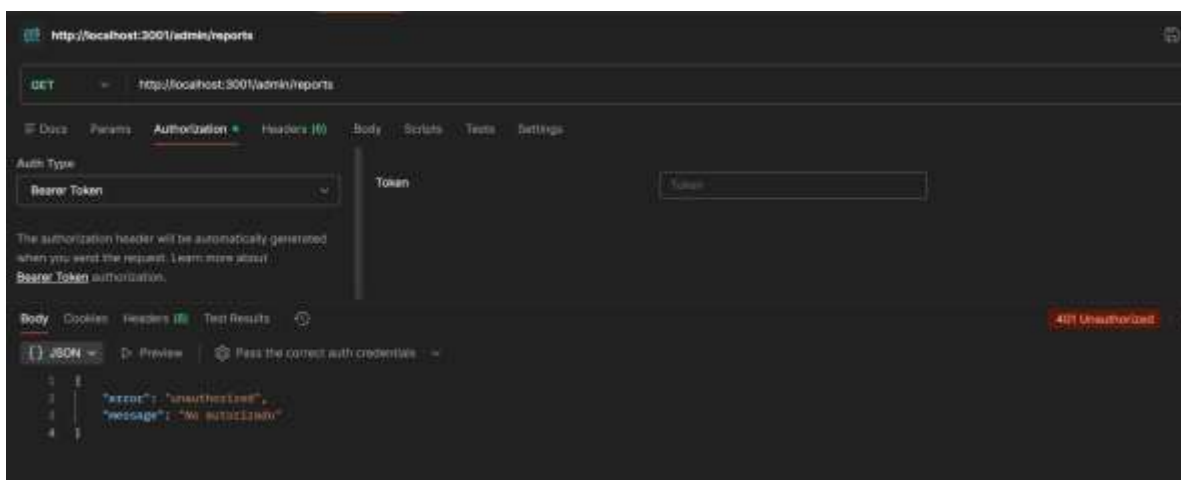
- usuario con rol admin → acceso permitido (200 OK).



- usuario con rol user → acceso denegado (403 Forbidden).



- usuario sin sesión → acceso denegado (401 Unauthorized).



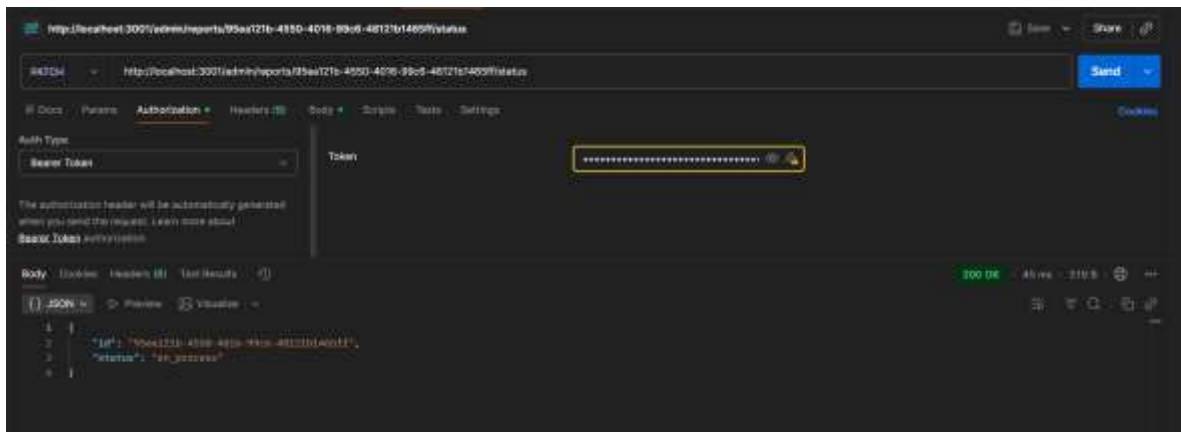
Con estas pruebas podemos comprobar que las funciones administrativas están correctamente protegidas por rol.

6. Cambio de estatus de reporte

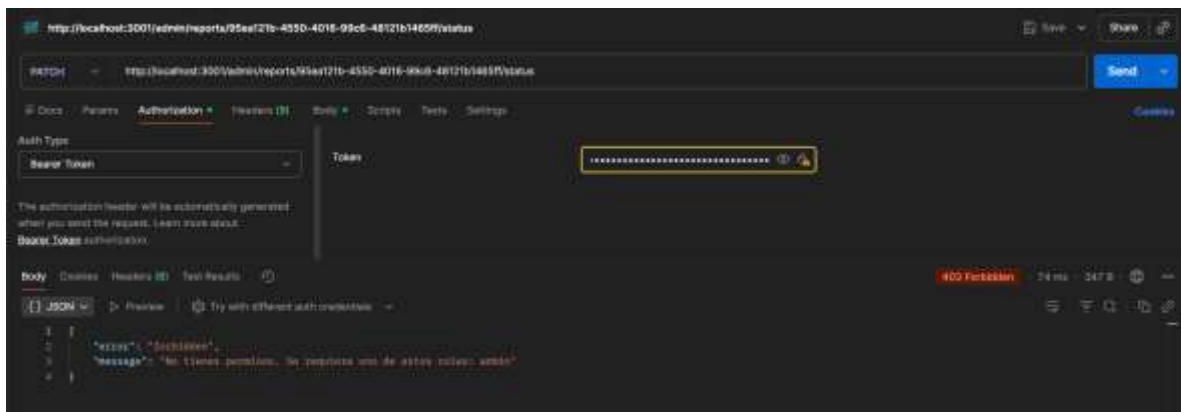
Se valida que únicamente un administrador pueda modificar el estado de un reporte.

Escenarios probados:

- admin con estado válido (pendiente, en_proceso, resuelto) → cambio exitoso (200 OK).



- usuario normal → acceso denegado (403 Forbidden).



Con esto se busca el garantizar que solo usuarios autorizados pueden modificar información crítica del sistema y que los valores sean validados correctamente.